CHAPTER 3 USER AUTHENTICATION

3.1 In the authentication protocol below, pw is A's password and J is a key derived from pw. Can an attacker that can eavesdrop messages (but not intercept or spoof messages) obtain pw by off-line password guessing? If you answer no, explain briefly. If you answer yes, describe the attack.

A (has pw)	B (has J)
send [conn] to B	
	generate random challenge R send [R]
compute J from pw compute X ← encrypt(R) with key J send [X] to B	
	compute Y ← decrypt(X) with key J if Y = R then A is authenticated

3.2 The chart below shows an authentication protocol, followed by data exchange, followed by disconnection. Only an initial part of the authentication protocol is shown; here, pw is A's password, J is a key derived from pw, and L is a high-quality key. Assume an attacker that can (1) eavesdrop messages and (2) intercept and spoof messages sent by A (but not those sent by B). Complete the authentication protocol (i.e., supply the part indicated by the "** …. * *") so that in spite of this attacker

- B authenticates A,
- this authentication is not vulnerable to off-line password guessing, and
- A and B establish a session key S (for encrypting data) such that after A and B disconnect and forget S, even if the attacker learns pw, the attacker cannot decrypt the data exchanged.

Copyright © 2024, 2018, 2015 by Pearson Education, Inc. or its affiliates.

	A (has pw)	B (has J, L)
	send [conn] to B	X ← encrypt(L) with key J send [X]
	compute J from pw L' ← decrypt(X) with key J	
*		
*		
*		
*		
*		
*		
*		
*		
	←A and B exchange data →	
	←A and B disconnect →	

3.3 Consider an Intrusion Detection System with a False Positive Rate of 0.001 and a False Negative Rate of 0.09.

a. If there are 100,000,000 legitimate transactions (connections) a day, how many false alarms will occur?

b. If there are 1000 hacking attempts (connections) per day, how many true alarms will be given?

c. How many hacking attempts will go unnoticed?

Copyright © 2024, 2018, 2015 by Pearson Education, Inc. or its affiliates.